信息系统安全

(Information System Security)

王鹃

国家网络安全学院

2020.07

课程内容

- 信息系统安全概述
- 软件安全与漏洞类型
- 渗透测试方法及工具
- 模糊测试与漏洞挖掘
- 用户身份认证机制
- 访问控制模型
- 操作系统基础安全机制
- 硬件安全与可信计算
- 系统风险评估方法与工具
- 信息系统安全研究新方向

课程目标

- 掌握信息系统安全的基本概念
- 熟悉信息系统安全常见攻击手段及原理和典型漏洞类型
- 掌握模糊测试和漏洞挖掘原理及工具使用
- 熟悉渗透测试方法及工具Kali
- 掌握身份认证原理及机制
- 掌握访问控制模型及机制
- 掌握操作系统基础安全机制
- 熟悉可信计算技术基本原理与技术
- 熟悉系统风险评估方法与工具
- 了解系统安全前沿发展

课程内容总结

- 了解信息系统的主要安全威胁
  - 掌握信息安全的基本属性（机密性、完整性、可用性）及其含义
  - 信息安全模型
- 熟悉信息系统安全常见攻击手段及原理和典型漏洞类型
  - 典型软件漏洞类型及原理，如缓冲区溢出
  - 恶意软件分类
  - 软件加壳和脱壳原理及方法
- 掌握模糊测试和漏洞挖掘原理及工具
  - 模糊测试原理
  - AFL
- 熟悉渗透测试方法及工具Kali
  - 渗透测试方法
  - Kali及其主要工具

课程内容总结

- 掌握身份认证原理及机制
  - 身份认证方法
  - Kerberos
- 掌握访问控制模型
  - 访问控制的概念
  - 自主访问控制、强制访问控制、基于角色的访问控制原理
- 掌握操作系统基础安全机制
  - Windows安全模型实现机制
  - 自主访问控制在LINUX的实现
  - Selinux访问控制及实现，LSM机制

课程总结

- 熟悉可信计算技术基本原理与技术
  - 可信计算的基本原理、关键技术
  - 可信平台的三个信任根，作用和区别
  - 可信启动的实现原理
  - 远程证明的作用
  - 了解TEE技术
- 熟悉系统风险评估方法与工具
  - 风险评估的内容
  - 了解风险评估及等级测试常用标准
  - CVSS
- 了解系统安全前沿发展
- 掌握Linux系统的使用方法
  - 常用防护方法

实验

实验：至少完成5个实验中的4个

1、基于OllyDbg的恶意代码分析
2、基于KALI和Metasploit的渗透测试
3、基于AFL的系统漏洞挖掘
4、Linux基本访问控制机制分析
5、TPM模拟器安装、使用和编程

课堂展示

课堂展示： 从第3周开始，每次课的最后一堂课

要求：

1、每组不超过3人，展示一种攻击手段或者一个防御系统，如展示攻击手段，尽量选择偏系统的，同时提出可能的防御方法。

2、制作PPT，讲解攻击或防御系统原理，PPT中介绍队员以及各自分工和贡献

3、现场演示，并录制视频

4、时间10-15分钟

5、展示内容（PPT+视频+工具）上传到网盘，以展示内容和队长名字+学号命名

进一步的学习

1、本课程涵盖内容的进一步深化和学习
2、以攻为防
3、积极参加各种攻防比赛
4、平时注意关注各种信息安全资讯
   freebuffer、安全牛、E安全、看雪学院
5、抓住一些兴趣点，深入钻研
6、有时间可以看看顶会论文

考试与考核办法

- 学分：2
- 学时：32（理论）
- 成绩
  - 考勤 （10%）
  - 实验（40%）
  - 课堂展示 （20%）
  - 考试（30%）